TESTE03 - Deepseek-r1

==========
SERVIDOR MCP
==========
Servidor MCP conectado.

Aguardando resposta do servidor...
Tempo de espera: 800 segundos

==========
RESPOSTA DO SERVIDOR
==========

Relatório de Segurança — fiware/orion

Resumo da Varredura:

- Blocos analisados: 11
- Vulnerabilidades descartadas (FIXED): 654

Análises Detalhadas

Parte 1 de 11

Análise de Vulnerabilidades no fiware/orion (debian 13.4):

Vulnerabilidades Relevantes:

1. **CVE-2026-76642 (bsdutils, libblkid1):** Falha ao verificar o status de retorno do helper de montagem externa, permitindo a execução de post-hooks privilegiados mesmo quando o helper falha. Pode levar a escalada de privilégios.
2. **CVE-2026-78408 (bsdutils, libblkid1):** Falha na manipulação de cgroups via nsenter --join-cgroup, permitindo exploração de vulnerabilidades de cgroups existentes no kernel (potencialmente relacionadas com o CVE-2026-76642).
3. **CVE-2026-78409 (bsdutils, libblkid1):** Vulnerabilidade no X-mount.subdir, permitindo escapamento via links simbólicos em sistemas Linux recentes (>=6.15). Pode levar a escalada de privilégios.

4. **CVE-2026-78410 (bsdutils, libblkid1):** Falha na retenção do caminho da fonte em mount restritos, permitindo redirecionamento via X-mount.owner/group/mode. Pode levar a escalada de privilégios.
5. **CVE-2026-12064 (curl):** Bypass de verificação de host SSH quando URLs sem esquema (schemeless) são usadas com SFTP/SCP. Risco de conexão não verificada com hosts remotos.
6. **CVE-2026-8458 (curl):** Reutilização inadequada de conexões libcurl, permitindo reutilização de conexões com serviços diferentes. Pode levar a vazamento de informações ou execução de comandos não autorizados.
7. **CVE-2026-54369 (libacl1):** Vulnerabilidade de travessia de links simbólicos nas funções de ACL. Pode levar a escalada de privilégios via manipulação de ACL.

Impacto Provável:

- **CVE-2026-76642, 78408, 78409, 78410:** Essas vulnerabilidades no util-linux (afetando bsdutils e libblkid1) têm um alto potencial de permitir a exploração por usuários não privilegiados (local ou, em alguns casos, remoto se Orion for exposto) para executar operações com privilégios elevados (como alterar permissões de arquivos, manipular cgroups, ou mesmo executar código arbitrário via bind mounts). Isso pode comprometer a integridade e a segurança do sistema.
- **CVE-2026-12064:** Pode resultar em conexões SSH não verificadas com hosts maliciosos, permitindo ataques como devoxy (supersede de credenciais) ou execução de comandos não autorizados se o usuário confiar a conexão.
- **CVE-2026-8458:** Pode levar a problemas de segurança relacionados com a reutilização de conexões, embora seu impacto exato dependa do contexto. Pode facilitar ataques de engenharia social ou exploração de outras vulnerabilidades.

Recomendações de Correção Práticas:

1. **Verifique Versões Atualizadas:** Identifique as versões mais recentes dos pacotes `bsdutils`, `libblkid1`, `curl`, `libacl1` disponíveis para o seu sistema Debian 13.4 (trixie). Verifique a compatibilidade com o fiware/orion antes de atualizar.
2. **Atualize os Pacotes:** Priorize a atualização dos pacotes vulneráveis (`bsdutils`, `libblkid1`, `curl`, `libacl1`) para as versões que corrigem os CVEs mencionados. Use gerenciadores de pacotes como `apt` com flags `--allow-downgrades` ou `--allow-change-held-packages` se necessário para obter versões mais recentes que contenham as correções.
3. **Verifique Dependências do Orion:** Confirme quais pacotes específicos do fiware/orion podem depender de `bsdutils`, `libblkid1`, `curl`, e `libacl1`. Atualizar apenas os pacotes base pode não ser suficiente se o Orion usar bibliotecas não atualizadas.

4. **Monitore Cgroups:** Se o Orion ou seus componentes usam cgroups, esteja atento às vulnerabilidades relacionadas ao kernel de cgroups (como CVE-2026-78408) e considere as implicações de segurança para suas contas e processos.
5. **Teste a Aplicação:** Após atualizar os pacotes, teste o fiware/orion rigorosamente para garantir que a funcionalidade não tenha sido comprometida e que as correções tenham sido aplicadas corretamente.

Essas vulnerabilidades são críticas e exigem correções urgentes para manter a segurança do sistema.

Parte 2 de 11

Análise de Vulnerabilidades no fiware/orion (Debian 13.4)

Visão Geral:
O sistema fiware/orion, executado no Debian 13.4, está vulnerável a múltiplos problemas de segurança de alta gravidade relacionados aos pacotes `util-linux` e `libcurl4t64`. As vulnerabilidades são críticas para sistemas de montagem e podem permitir manipulação de dados e escalada de privilégios.

Vulnerabilidades Relevantes:

1. **CVE-2026-78410 (Pacote: `util-linux`):**
   - **Impacto:** Permite que um usuário não privilegiado redirecione operações de montagem bind. Se a montagem inclui configurações específicas para alterar o dono ou o grupo do arquivo (X-mount.owner/group), o root pode modificar essas permissões no arquivo maliciamente redirecionado, potencialmente permitindo execução de código com privilégios elevados ou acesso não autorizado.
   - **Recomendação:** Atualizar o pacote `util-linux` para uma versão corrigida.
2. **CVE-2026-78408 (Pacote: `util-linux`):**
   - **Impacto:** Libera a capacidade do root de migrar processos entre cgroups para um usuário não privilegiado após a execução específica `nsenter --join-cgroup`. Isso pode permitir que o usuário não autorizado termine processos irrelevantes com privilégios de root.
   - **Recomendação:** Atualizar o pacote `util-linux` para uma versão corrigida.
3. **CVE-2026-78409 (Pacote: `util-linux`):**
   - **Impacto:** Permite que um usuário não privilegiado utilize a opção `X-mount.subdir` para montar caminhos do host fora do diretório de montagem pretendido, através de simbólicos intermediários, potencialmente acessando dados sensíveis ou executando operações indesejadas.

- **Recomendação:** Atualizar o pacote `util-linux` para uma versão corrigida.

4. **CVE-2026-76642 (Pacote: `util-linux`):**
   - **Impacto:** Permite que um usuário não privilegiado execute operações privilegiadas em sistemas de arquivos existentes se os helpers de montagem externos falhar (especialmente ao usar X-mount.idmap ou X-mount.owner). Pode levar a escalada de privilégios ou modificação de permissões.
   - **Recomendação:** Atualizar o pacote `util-linux` para uma versão corrigida.
5. **CVE-2026-12064 (Pacote: `libcurl4t64`):**
   - **Impacto:** Pode causar a conexão com um host SSH remoto não verificado quando um URL sem esquema (schemeless) é usado com `--proto-default sftp`. Isso expõe o sistema a ataques de degradação de serviço ou de suborno (man-in-the-middle) ao conectar-se a hosts falsos sem verificação adequada.
   - **Recomendação:** Evitar o uso de URLs sem esquema com protocolos SSH (`sftp`, `scp`) ou corrigir a verificação de host SSH na configuração do `curl`. Atualizar o pacote `libcurl4t64` é recomendado.
6. **CVE-2026-8458 (Pacote: `libcurl4t64`):**
   - **Impacto:** Pode levar a uma reutilização inadequada de conexões autenticadas de forma diferente, potencialmente permitindo a execução de requisições não autorizadas com as mesmas credenciais de autenticação, explorando vulnerabilidades em ambientes específicos.
   - **Recomendação:** Atualizar o pacote `libcurl4t64` para uma versão corrigida.

Conclusão:
O fiware/orion (Debian 13.4) possui várias vulnerabilidades de alta criticidade, principalmente no pacote `util-linux`. Estas vulnerabilidades podem comprometer a segurança do sistema, permitindo manipulação de montagens, escalada de privilégios e conexões não verificadas. Recomenda-se priorizar a correção das vulnerabilidades `util-linux` (CVE-2026-78410, CVE-2026-78408, CVE-2026-78409, CVE-2026-76642) devido à sua natureza de acesso e modificação de sistema, seguida pela correção do `libcurl4t64` (CVE-2026-12064, CVE-2026-8458) para conexões SSH.

Parte 3 de 11

Análise de Vulnerabilidades do fiware/orion (Debian 13.4):

Vulnerabilidades Relevantes:

- **CVE-2026-78410 (libmount1):** Versão 2.41-5 do util-linux.
- **CVE-2026-76642 (libsmartcols1):** Versão 2.41-5 do util-linux.

- **CVE-2026-78408 (libsmartcols1):** Versão 2.41-5 do util-linux.
- **CVE-2026-78409 (libsmartcols1):** Versão 2.41-5 do util-linux.
- **CVE-2026-16742 (libsystemd0 e libudev1):** Versão 257.9-1~deb13u1 do systemd-homed (via util-linux e libudev1).

Impacto Provável:

- **Escalada de Privilegios (Privilege Escalation):** Usuários não privilegiados podem potencialmente alterar montagens, redirecionar operações de SUID `mount`, executar post-hooks privilegiados, ou modificar atributos de inode, levando à execução de código não autorizado ou acesso a recursos.
- **Leak de Informações:** O vazamento de permissões de cgroup pode permitir que processos não autorizados movam processos do host entre cgroups e terminem processos arbitrários.
- **Escape de Monta (Mount Escape):** Usuários não privilegiados podem usar entradas específicas em `fstab` para montar diretórios do host não autorizados, potencialmente escapando do namespace ou alterando permissões.

Recomendações de Correção Práticas:

1. **Atualização Urgente:** Priorize a atualização do pacote `util-linux` para uma versão mais recente que corrija as vulnerabilidades (especificamente as relacionadas com libmount1 e libsmartcols1).
2. **Atualização do systemd-homed:** Atualize também o pacote `systemd-homed` (e possivelmente `libsystemd0`, dependendo da configuração) para a versão corrigida.
3. **Limitação de Capabilidade (Capabilities):** Considere restringir a execução do comando `mount` ou processos relacionados ao `util-linux` (como `newfs`) a usuários não root, se possível, para mitigar alguns riscos de escalada de privilégios. No entanto, isso pode ser complexo dependendo da arquitetura.
4. **Contenção:** Se uma atualização não for disponível ou possível imediatamente, contenha o sistema ou serviços suscetíveis até que possa ser aplicada a correção.

Parte 4 de 11

Análise de Vulnerabilidades do fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes:

1. **CVE-2026-78409 (libuuid1)**

- **Impacto Provável**: Violação de sandbox via montagem de diretórios usando caminhos simbólicos, permitindo que um usuário local não privilegiado monte um diretório host em um ponto montado autorizado, acessando caminhos inesperados.
- **Recomendação**: Atualizar o pacote `libuuid1` para a versão mais recente, onde o problema foi corrigido.

2. **CVE-2026-78410 (libuuid1)**
   - **Impacto Provável**: Escapagem de diretórios montados via bind, onde um usuário local pode alterar propriedades ou modo de montagem, potencialmente levando à alteração de permissões de arquivos sensíveis.
   - **Recomendação**: Atualizar o pacote `libuuid1` para a versão mais recente.
3. **CVE-2026-43185 (linux-libc-dev)**
   - **Impacto Provável**: Vulnerabilidade crítica de assinatura de dados no SMB, que pode ser explorada para executar código no sistema.
   - **Recomendação**: Atualizar o kernel para uma versão mais recente onde o bug foi corrigido.

Vulnerabilidades de Alto Risco (Antigas):

- **CVE-2013-7445 (linux-libc-dev)**: Vulnerabilidade no DRM que permite exaustão de memória via manipulação de GEM objects. Embora tenha CVE ID antigo, deve ser verificada se ainda está presente.
- **CVE-2019-19449/19814 (linux-libc-dev)**: Problemas no f2fs que podem causar acesso fora dos limites à memória.
- **CVE-2021-3847/3864 (linux-libc-dev)**: Escalada de privilégios via OverlayFS e manipulação de dump.
- **CVE-2024-21803/58015 (linux-libc-dev)**: Problemas recentes no bluetooth e no wifi, respectivamente.

Ações Práticas:

- Verifique a versão atual dos pacotes `libuuid1` e `linux-libc-dev` no sistema.
- Aplicar atualizações do Debian para versões mais recentes onde esses problemas foram corrigidos.
- Monitorar o sistema para atividades suspeitas, especialmente relacionadas a montagens de sistemas de arquivos ou uso de SMB.

Parte 5 de 11

Análise de Vulnerabilidades: fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes:

- **CVE-2025-38137**: linux-libc-dev (6.12.74-2)
- **CVE-2025-38187**: linux-libc-dev (6.12.74-2)
- **CVE-2025-38204**: linux-libc-dev (6.12.74-2)
- **CVE-2025-38421**: linux-libc-dev (6.12.74-2)
- **CVE-2025-39859**: linux-libc-dev (6.12.74-2)
- **CVE-2025-39862**: linux-libc-dev (6.12.74-2)
- **CVE-2025-40025**: linux-libc-dev (6.12.74-2)
- **CVE-2025-68174**: linux-libc-dev (6.12.74-2)

Impacto Provável:

- Todas as vulnerabilidades têm **GRAVIDADE ALTA** (HIGH).
  - **Use-After-Free** (CVE-2025-38137, CVE-2025-38187, CVE-2025-39859): Pode levar a execução de código arbitrário ou crashes.
  - **Out-of-Bounds Read/Write** (CVE-2025-38204, CVE-2025-38421): Pode causar corrupção de memória, crashes ou execução de código.
  - **Array Index Out-of-Bounds** (CVE-2025-38204): Pode resultar em acesso inválido e crashes.
  - **List Corruption** (CVE-2025-39862): Pode causar instabilidades no sistema.
  - **Out-of-Bounds Memory Access** (CVE-2025-38636): Vulnerabilidade de baixa impacto, mas pode ser explorada em contextos específicos.
  - **Race Condition** (CVE-2025-68174): Pode causar crashes do sistema ou execução de código malicioso.

Recomendações de Correção:

- **Atualize o kernel** para uma versão que inclua patches para todas as vulnerabilidades listadas.
  - Verifique a disponibilidade de atualizações para o fiware/orion no Debian.
  - A próxima atualização deve incluir correções para **todos os CVEs** mencionados.

Resumo:

- Todas as vulnerabilidades são críticas e exigem atualização do kernel o mais rápido possível.
- Priorize a aplicação de patches, especialmente para problemas de **Use-After-Free** e **Race Conditions**.

Parte 6 de 11

Análise de Vulnerabilidades para fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes:

1. **CVE-2025-68735 (linux-libc-dev):**
   - **Impacto:** Possível escalada de privilégios via uso indevido de um objeto liberado (UAF) no módulo drm/panthor.
   - **Recomendação:** Atualizar o kernel para uma versão corrigida.
2. **CVE-2026-23102 (linux-libc-dev):**
   - **Impacto:** Denial of Service (DoS) devido a restauração incorreta do contexto SVE, potencialmente causando leituras OOB ou SIGKILL.
   - **Recomendação:** Atualizar o kernel para uma versão que inclua o fix de SVE.
3. **CVE-2026-23208 (linux-libc-dev):**
   - **Impacto:** Leitura de dados OOB no ALSA/usb-audio.
   - **Recomendação:** Atualizar o kernel para corrigir a validação de frames.
4. **CVE-2026-23327 (linux-libc-dev):**
   - **Impacto:** Acesso indevido ao payload CXL, potencialmente causando leitura OOB.
   - **Recomendação:** Atualizar o kernel para validar o tamanho do payload antes do acesso.
5. **CVE-2026-31493 (linux-libc-dev):**
   - **Impacto:** Exploit de uso-after-free no RDMA/efa.
   - **Recomendação:** Atualizar o kernel para garantir a liberação adequada do contexto.
6. **CVE-2026-31536 (linux-libc-dev):**
   - **Impacto:** Tratamento inadequado de completions no SMB server.
   - **Recomendação:** Atualizar o kernel para ajustar o gerenciamento de completions.
7. **CVE-2026-31568 (linux-libc-dev):**
   - **Impacto:** Loops de exceção de acesso seguro no s390/mm.
   - **Recomendação:** Atualizar o kernel para adicionar fixups necessários.
8. **CVE-2026-43263 (linux-libc-dev):**
   - **Impacto:** Null pointer dereference no chips-media/wave5.
   - **Recomendação:** Atualizar o kernel para adicionar bloqueios.
9. **CVE-2026-46130 (linux-libc-dev):**
   - **Impacto:** Leitura OOB de bytes de paridade no dm-verity-fec.
   - **Recomendação:** Atualizar o kernel para refatorar a leitura de blocos.
10. **CVE-2026-46181 (linux-libc-dev):**
    - **Impacto:** Uso incorreto de RCU no mlx4_srq_event.

- **Recomendação:** Atualizar o kernel para adotar spinlock/refcount.

Impacto Provável:

- Todas as vulnerabilidades têm **impacto HIGH**, podendo causar:
  - Escalada de privilégios (CVE-2025-68735, CVE-2026-31493).
  - DoS ou instabilidades (CVE-2026-23102, CVE-2026-31536).
  - Leituras OOB ou corrupção de dados (CVE-2026-23208, CVE-2026-23327, CVE-2026-46130).
  - Null dereference (CVE-2026-43263).
  - Loops ou exceções não resolvidas (CVE-2026-31568).

Recomendações de Correção:

- **Atualize o kernel:** Para todas as vulnerabilidades, a correção mais prática é atualizar o kernel para uma versão que inclua os patches específicos (verifique os logs de segurança do Debian).
- **Verifique o contexto:** Para CVEs relacionados a UAF (ex: 2025-68735, 2026-31493), garantir que objetos sensíveis não sejam acessados após liberação.
- **Validação de dados:** Para problemas de OOB (ex: 2026-23208, 2026-23327), adicionar verificações de tamanho antes do acesso.
- **Monitoramento:** Após atualizações, verifique logs do sistema em busca de anomalias ou exploits pendentes.
- **Alternativa:** Se atualizações não forem viáveis, considere restringir acesso ao sistema ou usar ferramentas de mitigação como KASAN.

Parte 7 de 11

Análise de Vulnerabilidades no Fiware Orion (Debian 13.4):

1. **CVE-2026-46279 (linux-libc-dev)**
   - **Impacto Provável:** Uso de Memória Usada Após Liberação (Use-After-Free - UAF) que pode levar a execução remota de código ou informações sensíveis expostas.
   - **Recomendação:** Aplique patches upstream do kernel para corrigir a inicialização do codetag e o UAF. Não há correção específica de pacote para "linux-libc-dev" nesta CVE (2026).
2. **CVE-2026-52991 (linux-libc-dev)**
   - **Impacto Provável:** Condição de Corrida (Race Condition) que pode levar a uso de Memória Usada Após Liberação (UAF) ou exposição de informações (UAF via PSI)

durante operações de cgroup.
    - **Recomendação:** Aplique patches upstream do kernel para estender o bloqueio do cgroup_mutex na função `pressure_write()` e mover a verificação após a aquisição do lock de live kn.
3. **CVE-2026-64283 (linux-libc-dev)**
    - **Impacto Provável:** Tratamento incorreto de valores grandes para offset e tamanho em memslots de guest_memfd, potencializando a exposição de informações sensíveis ou rejeição inadequada de memslots.
    - **Recomendação:** Aplique patches upstream do kernel para tratar offset e tamanho como valores não assinados (`loff_t`) e adicionar os includes necessários no `kvm_mm.h` . Não há correção específica de pacote para "linux-libc-dev" nesta CVE (2026).

Nota: As CVEs mencionadas possuem datas (2026) que podem indicar versões futuras do kernel. Para versões *atualmente* em uso, verifique se há correções publicadas para estes problemas específicos no kernel correspondente. A correção prática geralmente envolve aplicar patches do kernel upstream ou aguardar atualizações da distribuição (Debian) para os pacotes do kernel relevantes.

Parte 8 de 11

Análise de Vulnerabilidades:

1. **CVE-2026-68409 (linux-libc-dev)**: Liberação inadequada de estatísticas RX em tempo real pode causar conflito de memória, potencialmente permitindo execução de código remoto.
2. **CVE-2026-68426 (linux-libc-dev)**: Conformidade de skb->prev após processamento de GSO pode levar a um uso indevido da memória (UAF), com risco de execução de código.
3. **CVE-2026-68470 (linux-libc-dev)**: Validação insuficiente de frames de extensão pode permitir execução de código remoto ou rejeitar pacotes maliciosos.
4. **CVE-2026-72042 (linux-libc-dev)**: Contagem de referências de usuário IPMI pode sofrer underflow, permitindo manipulação de memória.
5. **CVE-2026-72098 (linux-libc-dev)**: Cálculo de FEC pode causar buffer overflow, potencialmente permitindo execução de código remoto.
6. **CVE-2026-72463 (linux-libc-dev)**: Liberação UAF de dev durante a resumação assíncrona de xfrm.
7. **CVE-2026-74269 (linux-libc-dev)**: Cálculo incorreto do offset pode causar underflow de referência de página, levando a um uso indevido da memória (UAF).
8. **CVE-2026-74520 (linux-libc-dev)**: Contagem de referências de grupos IOPF pode sofrer UAF, com risco de execução de código.

9. **CVE-2026-74752 (linux-libc-dev)**: Validação insuficiente de cookies SCTP pode permitir acesso a dados não verificados, com risco de execução de código local ou remoto.
10. **CVE-2026-89631 (linux-libc-dev)**: Buffer overflow potencial no SMB ao processar respostas de conexão com byte count insuficiente.

Recomendações Práticas:

1. **Atualização Urgente:** Verifique e aplicar as patches do kernel mais recentes fornecidas pela distribuição Debian para corrigir todas essas vulnerabilidades (CVEs de 2026-68409 a 2026-89631).
2. **Monitoramento:** Verifique a lista de vulnerabilidades do kernel para novos anúncios e mantenha a atualização do sistema.
3. **Isolamento:** Considere isolar a instância do Orion se ela lidar com dados sensíveis ou operar em ambiente crítico, até que as correções estejam aplicadas e validadas.

Parte 9 de 11

Análise de Vulnerabilidades no Kernel do Linux para fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes:

1. **CVE-2026-89633 (linux-libc-dev):** Ocorrência de buffer bounds no SMB client.
2. **CVE-2026-89638 (linux-libc-dev):** Falta de atualização correta de permissões setuid/setgid no SMB.
3. **CVE-2026-89675 (linux-libc-dev):** UAF no NFSd durante teardown concorrente.

Impacto Provável:

- **CVE-2026-89633:** Possível exploração via SMB, levando a corrupção de memória (potencialmente execução remota).
- **CVE-2026-89638:** Vulnerabilidade de segurança nos controles de acesso, permitindo que setuid/setgid persistam indevidamente, o que pode levar a elevação de privilégios.
- **CVE-2026-89675:** Vulnerabilidade de uso de memória (Use-After-Free) no NFSd, que pode ser explorada para execução de código remoto.

Recomendações de Correção Práticas:

1. **Atualização do Kernel:** Priorize a atualização para a versão mais recente onde esses bugs foram corrigidos.
2. **Patches Específicos:** Se uma atualização geral não for disponível, aplique patches específicos para cada CVE identificado.

3. **Monitoramento e Auditoria:** Realize auditorias regulares e teste de penetração para garantir que as correções foram aplicadas com sucesso e não há outras vulnerabilidades.

Parte 10 de 11

Análise de Vulnerabilidades no fiware/orion (Debian 13.4):

Vulnerabilidades Relevantes:

1. **CVE-2026-98320 (linux-libc-dev):** Use-after-Free via references under RCU.
2. **CVE-2026-98364 (linux-libc-dev):** Use-after-Free via references under RCU.
3. **CVE-2026-76642 (login/mount):** Privilege escalation via unmonitored X-mount post-hooks.
4. **CVE-2026-78408 (login/mount):** Privilege escalation via unprivileged cgroup migration.
5. **CVE-2026-78409 (login):** Bypass of detached-tree fast path symlink resolution.
6. **CVE-2026-78410 (login):** SUID bit inheritance or inode modification via X-mount options.

Impacto Provável:

- **CVE-2026-98320, CVE-2026-98364:** Pode levar à execução de código remoto (possível execução arbitrária) ou crashes do sistema, explorando condições de concorrência (race conditions) na gestão de referências de conntrack.
- **CVE-2026-76642:** Pode permitir que um usuário não privilegiado execute operações privilegiadas em sistemas de arquivos existentes, potencialmente clonando sistemas de arquivos com bits suid incorretamente herdados ou modificando permissões.
- **CVE-2026-78408:** Pode permitir que um usuário não privilegiado mova processos do sistema (host) entre cgroups, potencialmente terminando processos arbitrários.
- **CVE-2026-78409, CVE-2026-78410:** Permitem o bypass de verificações de segurança em operações de mount, potencialmente levando a manipulação de sistemas de arquivos ou a alteração de permissões de inodes.

Recomendações de Correção Práticas:

Atualize os pacotes relevantes no seu sistema fiware/orion (Debian 13.4). Verifique as versões disponíveis no repositório do Debian para os pacotes `linux-libc-dev`, `login` e `mount` e instale as atualizações que corrigem as vulnerabilidades mencionadas (CVE-2026-98320, CVE-2026-98364, CVE-2026-76642, CVE-2026-78408, CVE-2026-78409, CVE-2026-78410). Se as atualizações não estiverem disponíveis imediatamente, considere a aplicação de patches ou mitigação adicional, mas isso deve ser feito com cautela. Sempre faça backup antes de atualizar.

Parte 11 de 11

Análise de Vulnerabilidades para fiware/orion (debian 13.4)

Vulnerabilidades Relevantes:

1. **CVE-2026-78409 (X-mount.subdir):** Pacote `util-linux` (versão 2.41-5). Impacto: **Alto**. Permite que um usuário não privilegiado, com uma entrada `fstab` autorizada, use a opção `X-mount.subdir` para afetar a resolução de montagens, potencialmente escapando para diretórios do host ou causando efeitos indesejados.
2. **CVE-2026-78410 (Restricted Bind Mounts):** Pacote `util-linux` (versão 2.41-5). Impacto: **Alto**. Falha nos montes de bind restritos permite que um usuário não privilegiado redirecione a operação de `mount` (se a entrada `fstab` inclui `X-mount.owner/group/mode`) para alterar permissões de inodes de forma inadequada, potencialmente levando a um aumento de privilégios.
3. **CVE-2026-76642 (External Mount Helper):** Pacote `util-linux` (versão 2.41-5). Impacto: **Alto**. Falha ao verificar o status de saída do helper de montagem pode permitir que um usuário não privilegiado execute operações `X-mount` post-hook mesmo após um erro no helper, possivelmente levando a privilege escalation.

Outras Vulnerabilidades (Menos Relevantes para o Orion):

- **CVE-2026-9538 (Perl Archive::Tar):** Pacote `perl-base` (versão 5.40.1-6). Impacto: **Alto**. Vulnerabilidade de buffer overflow no Perl que pode ser explorada via entrada maliciosa no comando `infocmp`, potencialmente levando a execução arbitraria de código. Requer um contexto Perl ativo com a biblioteca `Archive::Tar`.
- **CVE-2025-69720 (Buffer Overflow):** Pacotes `ncurses-base` e `ncurses-bin` (versão 6.5+20250216-2). Impacto: **Alto**. Buffer overflow no `infocmp` do ncurses. Requer uma entrada específica para ser ativada, menos direta para o Orion.

Recomendações de Correção Práticas:

1. **Atualizar `util-linux`:** Prioridade crítica. Atualize o pacote `util-linux` para uma versão mais recente que corrija os problemas relacionados a `X-mount.subdir` e bind mounts (`CVE-2026-78409`, `CVE-2026-78410`, `CVE-2026-76642`). Exemplo de comando: `sudo apt-get update && sudo apt-get install util-linux=2.42.*` (verifique a versão correta mais recente que contém as correções).
2. **Verificar `perl-base`:** Se o Orion ou dependências usam o Perl e processam tarballs, considere atualizar o pacote `perl-base` para uma versão mais recente que inclua a correção para `CVE-2026-9538`. Exemplo: `sudo apt-get update && sudo apt-get install perl-base=5.40.*` (nova versão segura).

3. **Verificar `ncurses`:** Embora menos crítica para o Orion, atualize os pacotes `ncurses-base` e `ncurses-bin` para a versão corrigida para `CVE-2025-69720`. Exemplo: `sudo apt-get update && sudo apt-get install ncurses-base ncurses-bin=6.5-20251213+` (ou versão específica corrigida).

Essas vulnerabilidades exigem correções urgentes para garantir a segurança do sistema fiware/orion.